PORTSWIGGER LAB COMPLETION REPORT

API Testing

Name: Muhammad Afnan K O

Focus: WAPT

Platform: portswigger.com

1. Objective — What was the task about?

The main objective of this lab was to understand the vulnerabilities arises in API calls in a website. This include checking the website for api endpoints which are the locations where api receive the call api calls, after identifying endpoints we need to determine how to interact with the api. Then we craft http request to the api call to get the information from thew from website.

2. Concept/Understanding — What did you learn?

I have learned that api testing involve finding the api endpoints which is the first step in this testing which checks where the api call s are located , this is usually found in the url location or we can see the path in the network option of the developer tools of the website also in burpsuite. The api are crafted using JSON or XML. The http request which are used in this testing are GET, PATCH< OPTIONS, POST, DELETE. Also we need to understand which are the supported content types , api usually need some data to get the response, thus parameters must be needed, Some api needs to add http header content-type to allow which type of data is api is using like application/json,

3. Practical Work — What did you perform?

I completed a total of 5 labs in api testing which are 1.**Exploiting an API endpoint using documentation**, 2.**Exploiting server-side parameter pollution in a query string**, 3.**Finding and exploiting an unused API endpoint**, 4.**Exploiting a mass assignment vulnerability**, 5.**Exploiting server-side parameter pollution in a REST URL**. In the first lab I understood how to exploit an api documentation , in this I navigated to the api documentation path and deleted a user using the api call thus completed the first lab.

In the second lab I found a forgot password field and I requested it with administrator as the username and I send the request to the repeater and send it , it shows the hashed email and username of the admin, and in the request field there are 2 parameter username and csrf token, in here at the end of username I added '#' symbol in url encoded and send it in response field it gave field not specified and I bruteforced the field

and got email and it works with email parameter , and I checked the password reset script file I saw the reset_token parameter and I send the parameter in field option I got the reset token , I gave the reset token in password reset url then the reset page opened and I reset the password for admin and ogged as admin and deleted the user carlos as the lab objective.

In the third lab an unused end point which is a discount field in the api request , I checked the http history and found api get request for an item which included item details with price in json format and then I change the get to options which responded that only get and patch requests are allowed then I changed to patch request and added content type to application/json and added pricr parameter set to 0 in the argument and send it which resulted in price of the product to decrease to zero and bought it thus completed the lab.

In the fourth lab the same as in the third lab but in here in checkout POST request there included a json field I added a discount parameter which is only visible in GET request , I added the discount percentage to 100 which ordered the product for free thus completed the lab.

In the fifth lab which is also same as second lab same objective which is to delete user carlos with administrator account, same procedure is followed but the request to get the passwordResetToken is send by traversing the path to upper directory which bypassed the security and gave the reset token in response field.

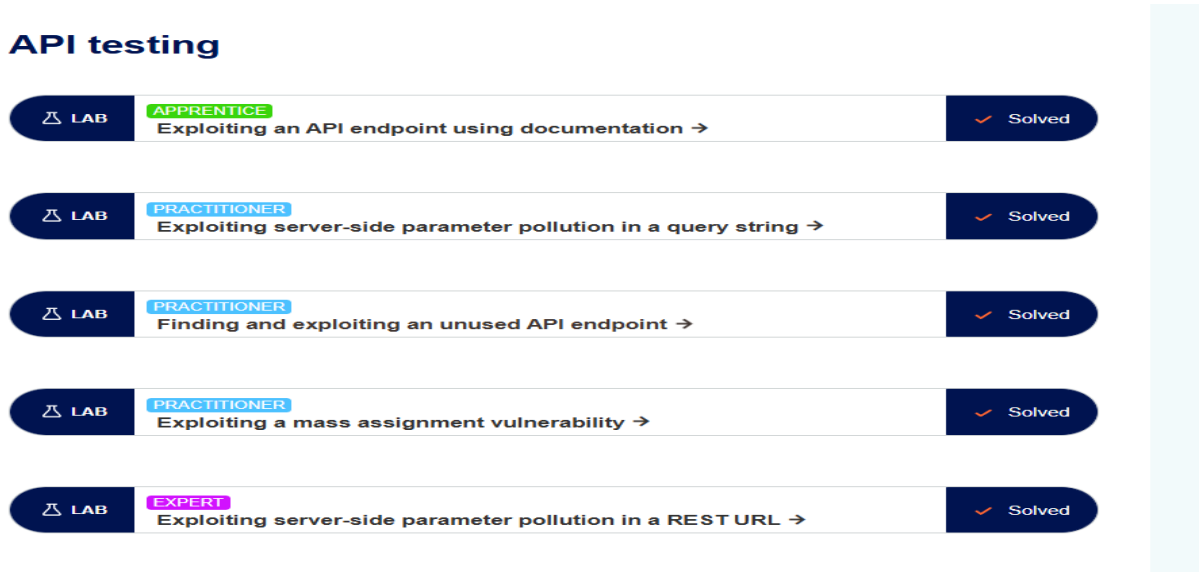
4. Tools Used — Tools used during the task.

- Portswigger website
- Browser Developer tools
- Burpsuite

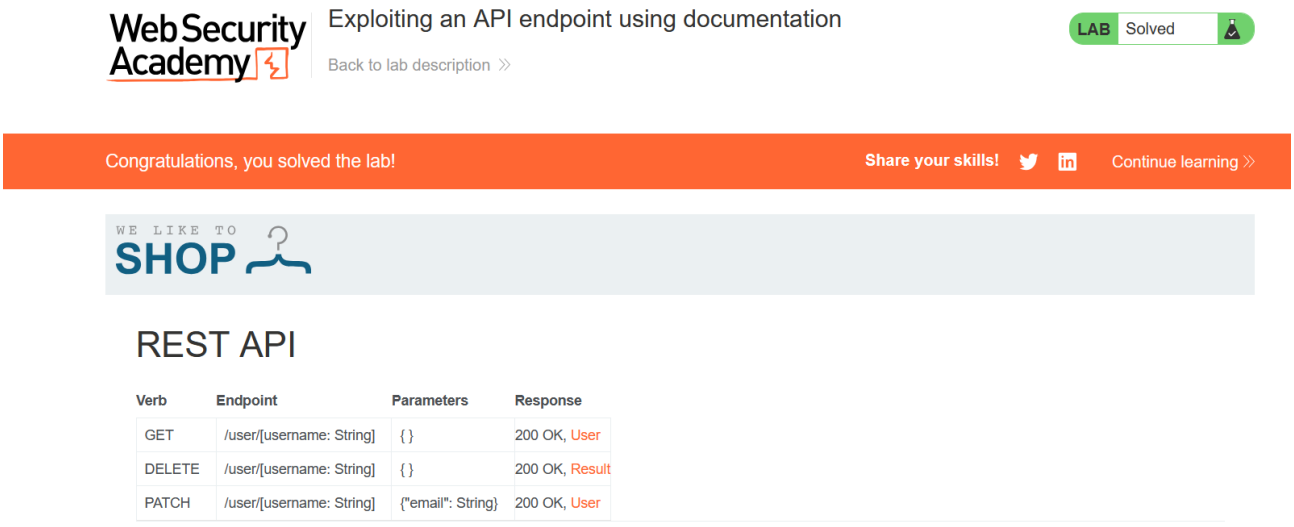
5. Evidence — Relevant screenshots and results.

Screenshots of the completed TryHackMe rooms, practical exercises, and relevant results can be added below as evidence of the work completed.

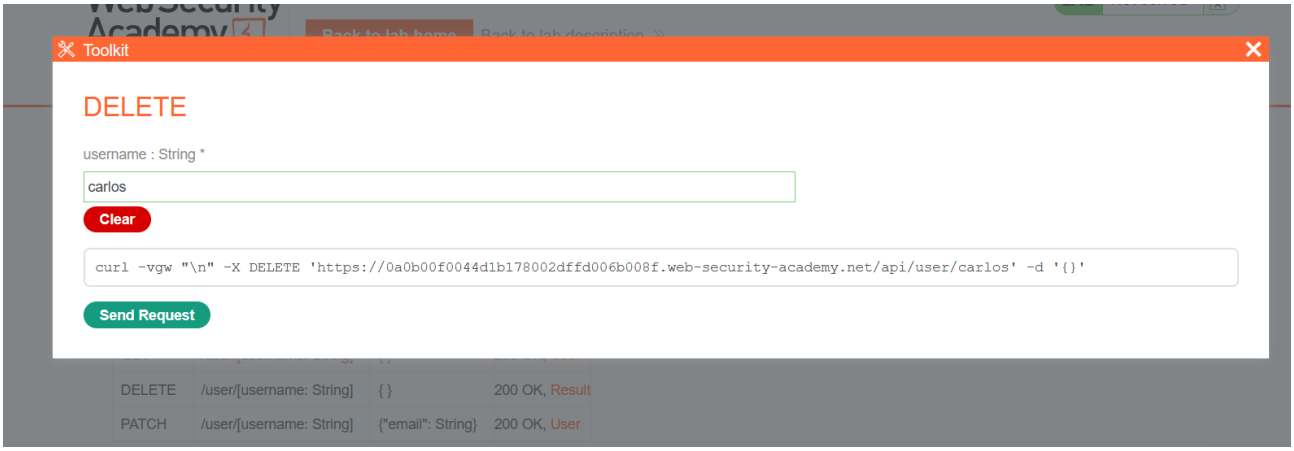
1.API Testing all lab completion:-



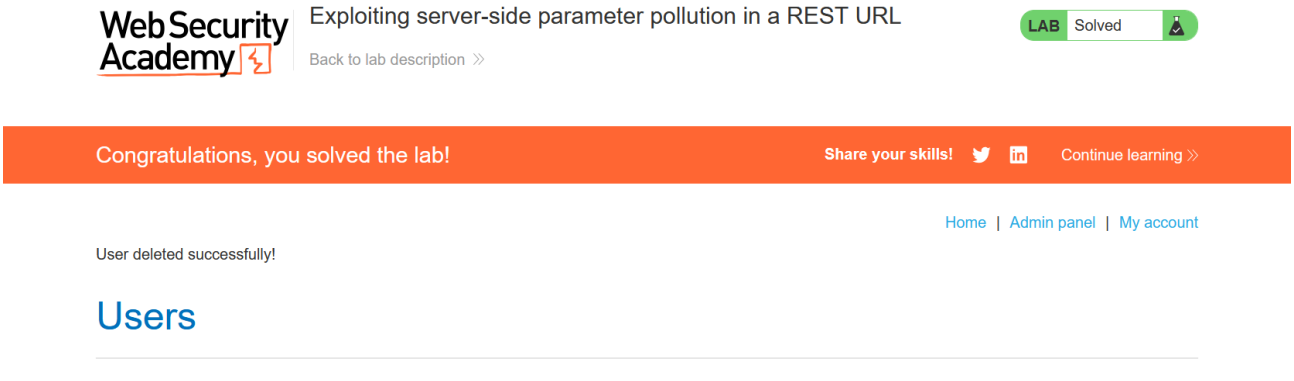
2.Screenshot of Room_1 **Exploiting an API endpoint using documentation** completion:-



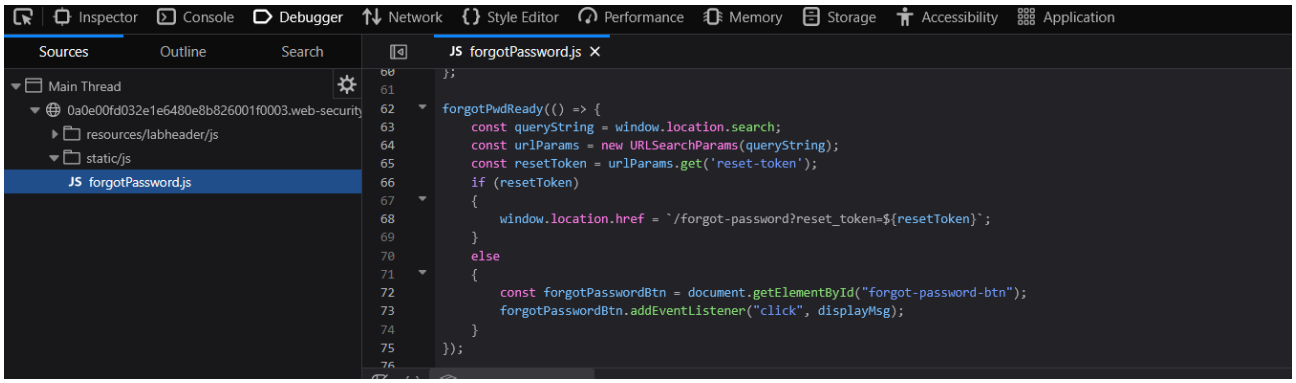
3.Screenshot of using endpoint documentation to delete user carlso:-



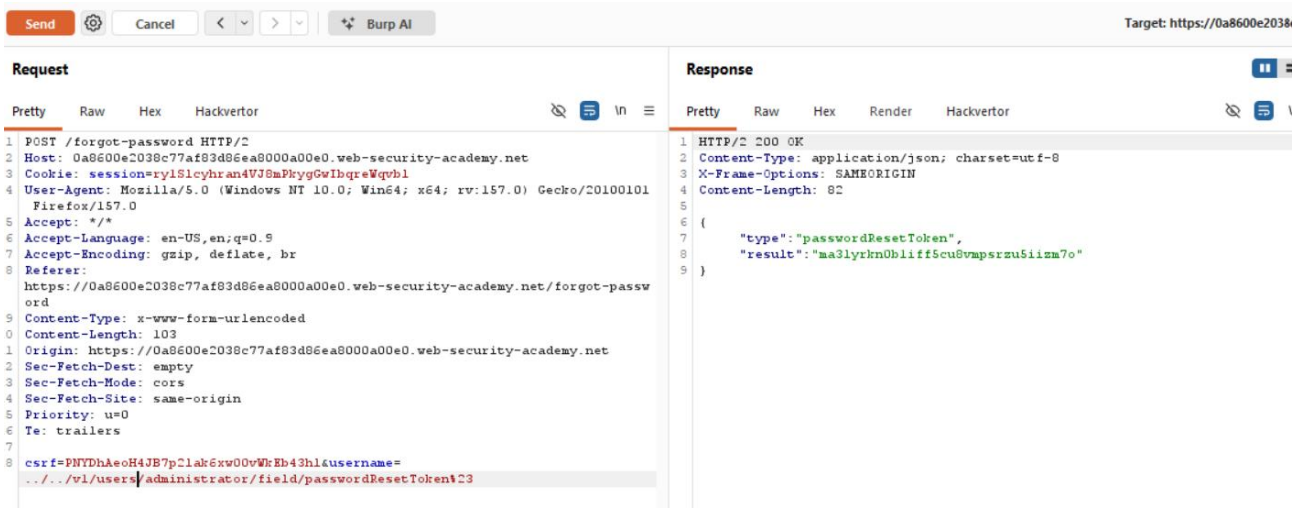
4.Screenshot of Room_2 .**Exploiting server-side parameter pollution in a query string** Completion:-



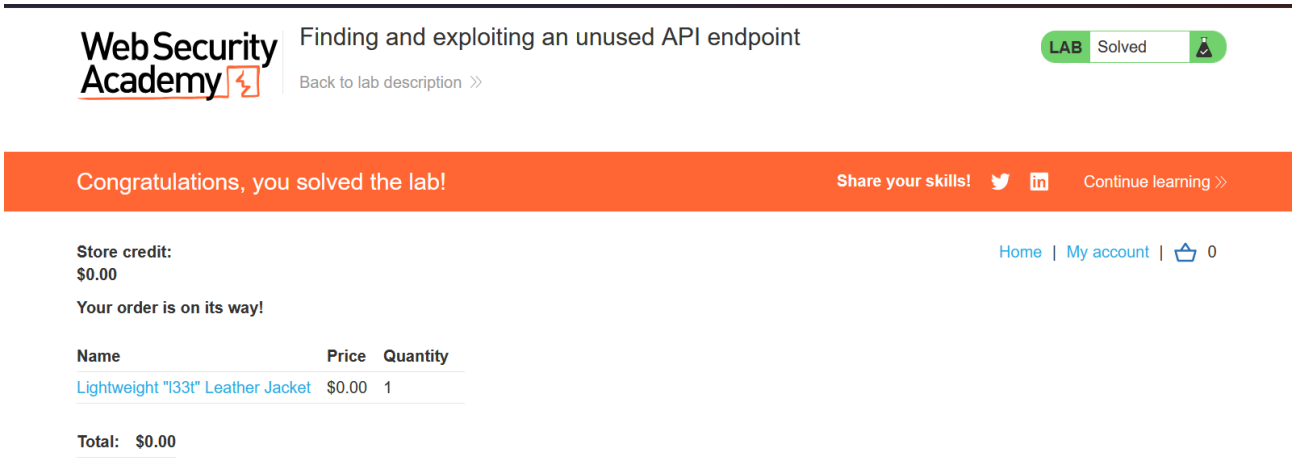
5.Screenshot of finding field value in passwordreset script in debugger:-



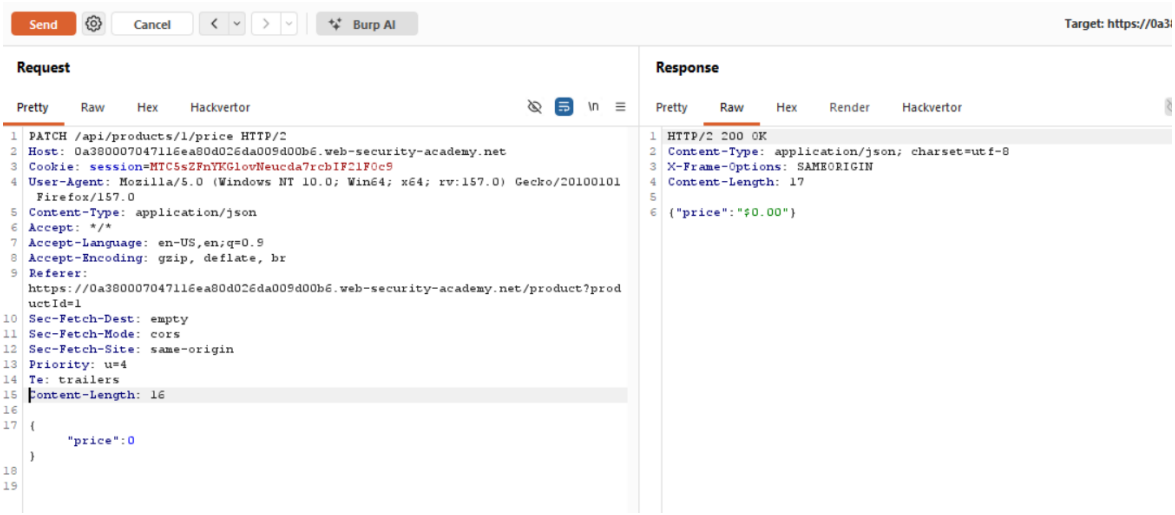
6.Screenshot of finding password reset token in the burp repeater using path traversal:-



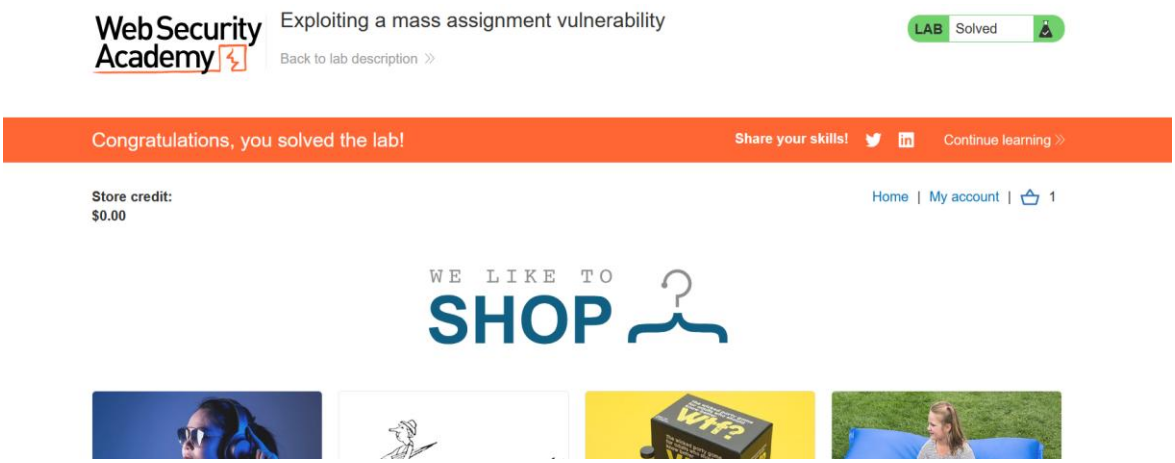
7.Screenshot of Room_3 .**[Finding and exploiting an unused API endpoint](#) Completion:-**



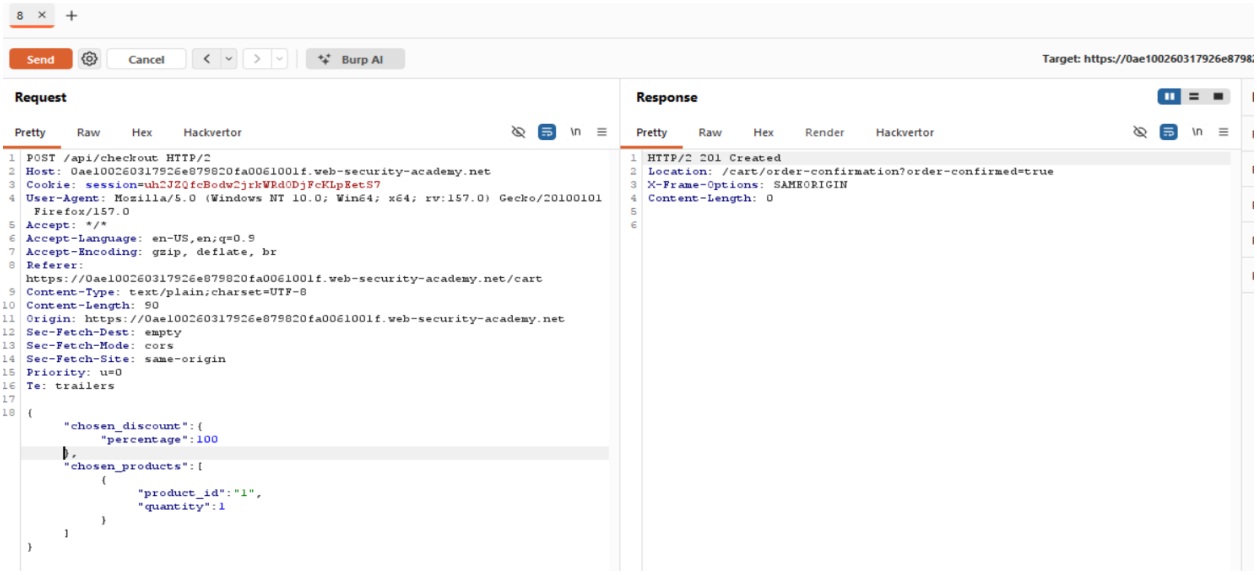
8. Screenshot of exploiting the unused endpoint in Burp Repeater:-



9.Screenshot of Room_4 [Exploiting a mass assignment vulnerability] Completion:-



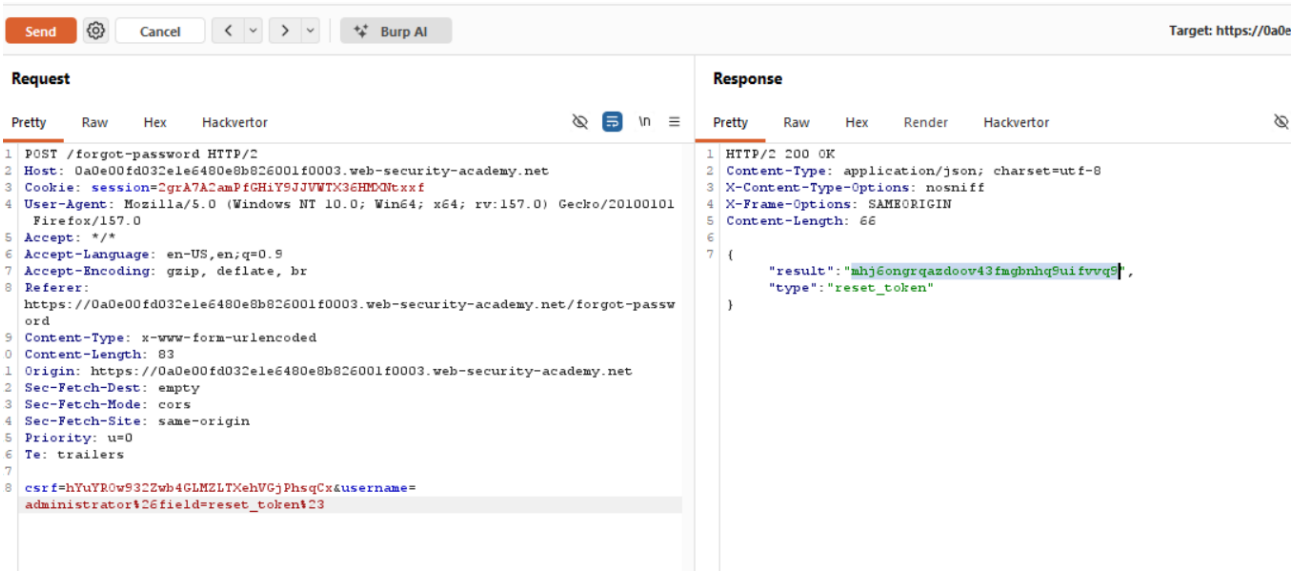
10.Screenshot of Exploiting the api in the checkout request:-



11.Screenshot of Room_5 [Exploiting server-side parameter pollution in a REST URL](#) Completion:-



12.Screenshot of Exploiting the password reset using parameter Pollutuion:-



6. Result — What did you achieve or discover?

I completed API testing Labs in Portswigger and gained better Understanding how to find api endpoints and identify them, also to identify their path and working , These labs gave me real world experiances of how vulnerabilities exist in a system and identify them, and also understood how to use burpsuite repeater to identify the api endpoints and to exploit them. These labs helped me to gain a better footing in the penetratrion testing career.

7. Key Learnings — What did you learn from the task?

- Understood the meaning and basic working of API vulnerabilities.
- Learned How to find api endpoints in a website and their path.
- Api are created using Json/xml format.
- Most websites uses api calls to simplify the processes or requests.
- Api vulnerabilities can be devastating according to the threats ina system or a threat actor.

Conclusion

By Completing these five API testing labs helped me understand how APIs work and how to identify common security issues. I gained practical experience using Burp Suite to inspect and modify requests and analyse server responses. These labs also improved my understanding of authentication, access control, and API vulnerabilities. Overall, this hands-on experience strengthened my basic API penetration testing skills and gave me more confidence in testing web application security. I learned how to identify the api endpoints and api paths in a website and how to exploit them.